

IA & données d'entreprise

Conformité LPD et protection du secret d'affaires — guide de choix des outils

Aide à la décision — sécurité de l'IA en entreprise suisse

Version du 5 juin 2026

Ce guide se lit en trois temps. L'arbre de décision répond à « ai-je le droit ? ». La matrice des verdicts répond à « avec quel outil, et mon secret d'affaires tient-il ? ». Le tableau de réalité opérationnelle indique, une fois l'outil choisi, ce qui va peser dans la mise en œuvre.

Il s'adresse à toute PME suisse régulée — cabinet immobilier, fiduciaire, étude d'avocats, structure de santé, gestionnaire de fortune, family office — qui veut intégrer l'IA sans exposer ses données ni son secret d'affaires.

1. Arbre de décision — ai-je le droit ?

Suivez les questions dans l'ordre. La première réponse qui débouche sur un verdict vous arrête ; sinon, continuez.

- 1. Les données contiennent-elles des données personnelles ?** (noms de clients, locataires, ou parties prenantes financières, coordonnées, identifiants, dossiers médicaux, données RH...)
 - Non : risque LPD faible. Passez à la matrice (section 2) pour vérifier le secret d'affaires.
 - Oui : passez à la question 2.
- 2. Peut-on anonymiser durablement les données avant traitement** (réidentification à effort disproportionné) ?
 - Oui : les données sortent du champ de la LPD — large flexibilité. Rare en pratique pour des données immobilières, financières ou de santé, souvent réidentifiables par recoupement (rapprochement avec un registre foncier, un cadastre patient, une base actionnariat).
 - Non / pseudonymisation seulement : la donnée reste personnelle. Passez à la question 3.
- 3. Données sensibles, secret particulier, ou traitement dans le périmètre de l'externalisation FINMA ?**
 - Oui : exigences renforcées : résidence suisse + DPA obligatoires, fournisseur souverain à privilégier. Évaluer la notification FINMA (Circ. 2018/3) et le plan de sortie. Le même réflexe vaut pour le secret médical (art. 321 CP) et le secret professionnel de l'avocat.
 - Non : passez à la question 4.
- 4. Le fournisseur garantit-il par contrat : aucun entraînement sur vos données, un DPA signé et des mesures de sécurité adéquates ?**
 - Non : proscrit (cas typique : ChatGPT personnel).
 - Oui : passez à la question 5.
- 5. Où les données sont-elles traitées ?**
 - Suisse ou UE : feu vert, sous réserve du DPA et des garanties.
 - États-Unis ou pays tiers : conditionnel : mécanisme de transfert (DPF ou CCT + TIA), analyse du risque Cloud Act, idéalement CMK/HYOK + calcul confidentiel.

2. Matrice des verdicts

Le groupe de gauche évalue la conformité LPD ; le groupe de droite, la protection effective du secret d'affaires. Un outil peut satisfaire l'un sans l'autre. Les marqueurs a, b, c renvoient aux conditions de la section 4.

Outil	Résidence	DPA	No-train	Verdict LPD	CMK / clés	Cloud Act	Verdict secret d'affaires
ChatGPT perso (Free/Plus)	US	Non	Non	Non conforme	Non	Élevé	Exposé
ChatGPT Team / Enterprise	US (UE en option)	Oui	Oui	Conforme sous cond. a	Non	Élevé	Risqué

Outil	Résidence	DPA	No-train	Verdict LPD	CMK / clés	Cloud Act	Verdict secret d'affaires
API OpenAI (+ ZDR)	US	Oui	Oui	Conforme sous cond. a	Non	Élevé	Risqué
Azure OpenAI (CH North)	CH	Oui	Oui	Conforme	Oui (+ HYOK)	Moyen	Bon b
AWS Bedrock (Zurich)	CH	Oui	Oui	Conforme	Oui (+ HYOK)	Moyen	Bon b
Infomaniak AI (API)	CH	Oui	Oui	Conforme	Chiffrement CH	Nul	Protégé
Self-host (Ollama / on-prem)	CH requis c	Sans objet	Oui	Conforme c	Total	Nul c	Maximal c

Légende : vert = conforme / risque faible · orange = sous conditions · rouge = non / risque élevé.

3. Réalité opérationnelle

La matrice dit si un outil est acceptable ; ce tableau dit ce qui vous attend une fois le choix fait.

Outil	Points d'attention (réalité opérationnelle)
ChatGPT perso (Free / Plus)	Le cauchemar du Shadow IT. L'entreprise n'a aucun contrôle d'accès ni visibilité sur ce que les employés copient-collent — qu'il s'agisse d'un mandat de gérance, d'un dossier patient ou d'une note d'analyse financière.
ChatGPT Team / Entreprise	Faux sentiment de sécurité. Protège contre l'entraînement, mais pas contre une injonction étrangère. Exige une gouvernance stricte (SSO) pour bloquer les données sensibles.
API OpenAI (+ ZDR)	Nécessite un middleware. Prévoir un script « tampon » en amont pour filtrer ou pseudonymiser les requêtes avant qu'elles ne partent aux États-Unis.
Azure OpenAI (CH North)	Lourdeur de configuration. Le niveau « Bon » suppose d'empiler HYOK, calcul confidentiel (TEE) et exemption de journalisation. Complexité Azure à maîtriser.
AWS Bedrock (Zurich)	Profil jumeau d'Azure CH. Souveraineté par empilement (KMS externalisé + Nitro Enclaves). Large catalogue de modèles, mais même exposition Cloud Act au niveau de l'infrastructure.
Infomaniak AI (API)	Écart de performance. Les modèles ouverts proposés sont excellents pour des tâches définies, mais peuvent rester en retrait des modèles frontière propriétaires sur les raisonnements très complexes.
Self-host (Ollama / on-prem)	Le piège de l'infrastructure. Le risque se déplace vers votre sécurité interne (accès, sauvegardes, durcissement). Coûts de calcul (GPU) souvent cachés.

4. Lecture des verdicts et conditions

Le verdict LPD dépend de la chaîne résidence + DPA + non-entraînement + encadrement du transfert. Le verdict secret d'affaires dépend de qui peut, de fait, accéder au contenu : maîtrise des clés et exposition au Cloud Act.

Conditions des astérisques

a : Transfert vers les États-Unis. « Conforme » seulement si le mécanisme de transfert est en place : fournisseur certifié Swiss-US DPF (adéquation reconnue depuis septembre 2024, à vérifier sur la liste officielle dataprivacyframework.gov/list, certification annuelle), ou clauses contractuelles types + analyse d'impact (TIA). Le statut DPF d'OpenAI est ambigu selon les sources ; Microsoft est certifié.

b : Niveau « Bon » (Azure, Bedrock). Atteint uniquement en empilant clé en HYOK (hors d'atteinte de l'hébergeur), calcul confidentiel (TEE) pour l'inférence et exemption de journalisation. Sans ces couches, le verdict retombe à « Moyen ».

c : Self-host. Valable à deux conditions : serveur physiquement en Suisse (matériel propre ou hébergeur suisse type Infomaniak ; un VPS étranger ou un cloud américain fait retomber la résidence et peut réintroduire le Cloud Act par la couche infrastructure), et sécurité interne (accès, sauvegardes, durcissement) à la hauteur.

À garder en tête

- **Conformité LPD ≠ secret d'affaires :** ChatGPT Enterprise et l'API peuvent être conformes tout en laissant le secret d'affaires « risqué » (pas de CMK, maison-mère américaine dans le périmètre du Cloud Act).
- **Cloud Act :** les autorités suisses ne le considèrent pas comme contraire en soi à l'ordre public suisse ; c'est un risque à documenter et à mitiger, pas un veto, d'où des verdicts « risqué / bon » et non « interdit ».
- **Secret d'affaires :** juridiquement protégé par les clauses de confidentialité du DPA, la LCD (art. 6) et le Code pénal (art. 162) ; mais ces protections ne tiennent pas face à une injonction étrangère qui les court-circuite. Pour les régimes spéciaux (secret bancaire art. 47 LB, secret médical art. 321 CP, secret professionnel de l'avocat art. 321 CP), la base légale est plus dure mais la mécanique d'exposition reste la même.
- **ChatGPT Team / Enterprise :** résidence UE possible en Enterprise, jamais en Suisse.

5. Cas des agents de codage (Claude Code, Antigravity, Copilot, Cursor, Codex...)

De plus en plus utilisés, ces outils ne sont pas une ligne de la matrice : ce sont des clients / agents, pas des backends d'hébergement. Leur conformité n'est pas intrinsèque : elle hérite du moteur d'inférence vers lequel ils sont configurés. « Cet agent est-il conforme ? » n'a de réponse qu'une fois précisé sur quel backend il tourne.

Rattachement aux lignes de la matrice

- **Claude Code :** configurable. Par défaut il appelle l'API Anthropic (US) → profil « API OpenAI ». Routé vers Bedrock, Vertex ou Foundry (région européenne ou cloud privé) → profil « Azure / Bedrock CH ». Attention au plan : en commercial (API, Bedrock, Vertex, Team, Enterprise) pas d'entraînement, mais sur un plan grand public (Pro/Max) l'entraînement peut être actif par défaut : même piège que ChatGPT personnel.
- **Antigravity (Google) :** cloud-native ; le code part par défaut sur les serveurs de Google → profil « US ». Via la plateforme Google Cloud entreprise (région suisse, Google certifié DPF), il se rapproche du profil « Azure / Bedrock CH ». En exécution locale (Ollama), il rejoint le profil « self-host ».
- **Règle générale :** un agent vaut ce que vaut son backend ; reportez-vous à la ligne correspondante de la matrice.

Deux règles propres aux agents

- **Périmètre :** un agent de codage touche du code, pas des données de production. Le garder sur du code et des données de test ou synthétiques, jamais sur des données personnelles ou réglementées réelles (dossiers clients, locataires, patients, actionnaires, bénéficiaires effectifs). Surveiller les secrets (clés API, mots de passe, identifiants de bases métier) qui ne doivent finir ni dans un prompt ni dans un cache local.
- **Accès local :** ces agents lisent le dépôt, exécutent des commandes (terminal) et pilotent parfois un navigateur ; certains conservent les transcripts en clair localement. La surface d'exposition (exfiltration, injection de prompt) est plus large qu'un simple chatbot et appelle un contrôle d'accès strict et une revue des actions.

6. Compléments requis avant déploiement

Pour toute option faisant intervenir un tiers

- DPA / contrat de sous-traitance signé (art. 9 LPD).
- Mécanisme de transfert pour tout flux hors CH/UE : adéquation Swiss-US DPF (statut vérifié) ou CCT + analyse d'impact (TIA).
- Confirmation contractuelle du non-entraînement (et du zero-data-retention si disponible).
- AIPD (analyse d'impact) si le risque est élevé.
- Mise à jour du registre des traitements et de la politique de confidentialité ; information des personnes concernées.
- Mesures techniques : chiffrement, contrôle d'accès, journalisation.

Spécifique aux branches Azure / Bedrock (région CH)

- Clé externalisée en HYOK, hors d'atteinte de l'hébergeur (Azure Key Vault Managed HSM / AWS KMS external key store).
- Calcul confidentiel (TEE / Nitro Enclaves) pour protéger l'inférence.
- Exemption de journalisation des invites (« no data logging »).

Périmètre FINMA et gouvernance

- Notification d'externalisation, clause d'audit, plan de réversibilité (Circ. 2018/3).
- Politique interne d'usage de l'IA + classification des données (quel outil pour quel type de donnée : mandat de gérance, dossier patient, note d'investissement, dossier RH, code applicatif...).

7. Glossaire

- **LPD** : Loi fédérale suisse sur la protection des données, dans sa version révisée en vigueur depuis le 1er septembre 2023.
 - **RGPD** : Règlement général européen sur la protection des données ; s'applique dès qu'on traite des données de personnes dans l'UE.
 - **Donnée personnelle** : Toute information se rapportant à une personne identifiée ou identifiable.
 - **Anonymisation** : Rupture durable du lien avec la personne (réidentification à effort disproportionné) ; sort la donnée du champ de la loi.
 - **Pseudonymisation** : Remplacement des identifiants par un pseudonyme, clé conservée à part ; la donnée reste personnelle.
 - **DPA** : Data Processing Agreement / contrat de sous-traitance encadrant le traitement par un tiers (art. 9 LPD).
 - **CCT / SCC** : Clauses contractuelles types : mécanisme de garantie reconnu pour les transferts transfrontières.
 - **Swiss-US DPF** : Data Privacy Framework : depuis le 15 septembre 2024, voie d'adéquation pour les transferts vers les entreprises US certifiées (certification annuelle).
 - **TIA** : Transfer Impact Assessment : analyse d'impact du transfert, requise hors voie d'adéquation.
 - **ZDR** : Zero Data Retention : le fournisseur ne conserve pas les données envoyées via l'API.
 - **CMK** : Customer-Managed Keys : vous fournissez et contrôlez vos clés de chiffrement au lieu de celles du fournisseur.
 - **HYOK** : Hold Your Own Key : la clé reste hors d'atteinte de l'hébergeur (chez vous ou un tiers de confiance suisse).
 - **TEE / Calcul confidentiel** : Trusted Execution Environment : protège la donnée pendant son traitement, en mémoire (l'angle mort du CMK).
 - **Cloud Act** : Loi américaine permettant d'exiger d'une entreprise US la communication de données, y compris stockées hors des États-Unis.
 - **AIPD** : Analyse d'impact relative à la protection des données, requise en cas de risque élevé.
 - **FINMA (Circ. 2018/3)** : Cadre suisse de l'externalisation applicable aux établissements financiers.
-

8. Avertissement

Ce document est une aide à la décision ; il ne constitue pas un avis juridique. La qualification précise des données et la conformité d'un déploiement donné doivent être validées par un conseil juridique spécialisé, en particulier sur les volets FINMA, secret médical et secret professionnel. Les caractéristiques des fournisseurs (résidence, options de chiffrement, statut DPF, conditions contractuelles) évoluent et doivent être vérifiées au moment de la contractualisation.